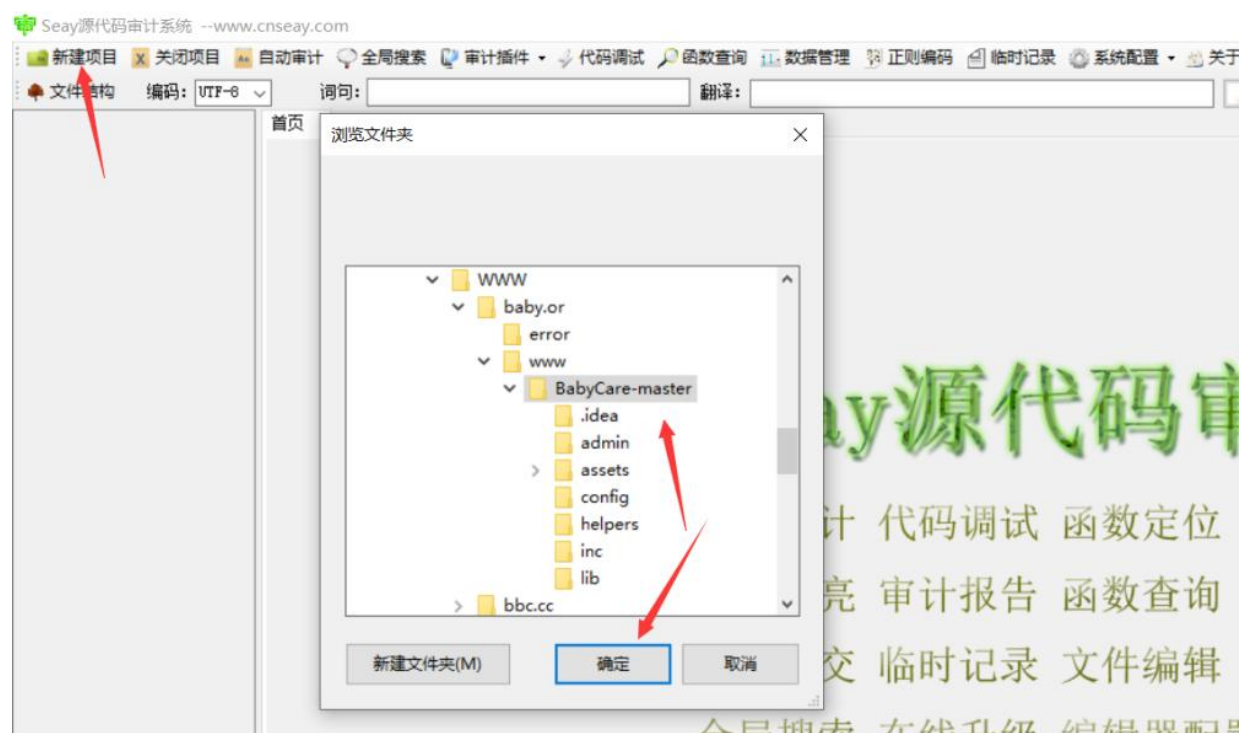


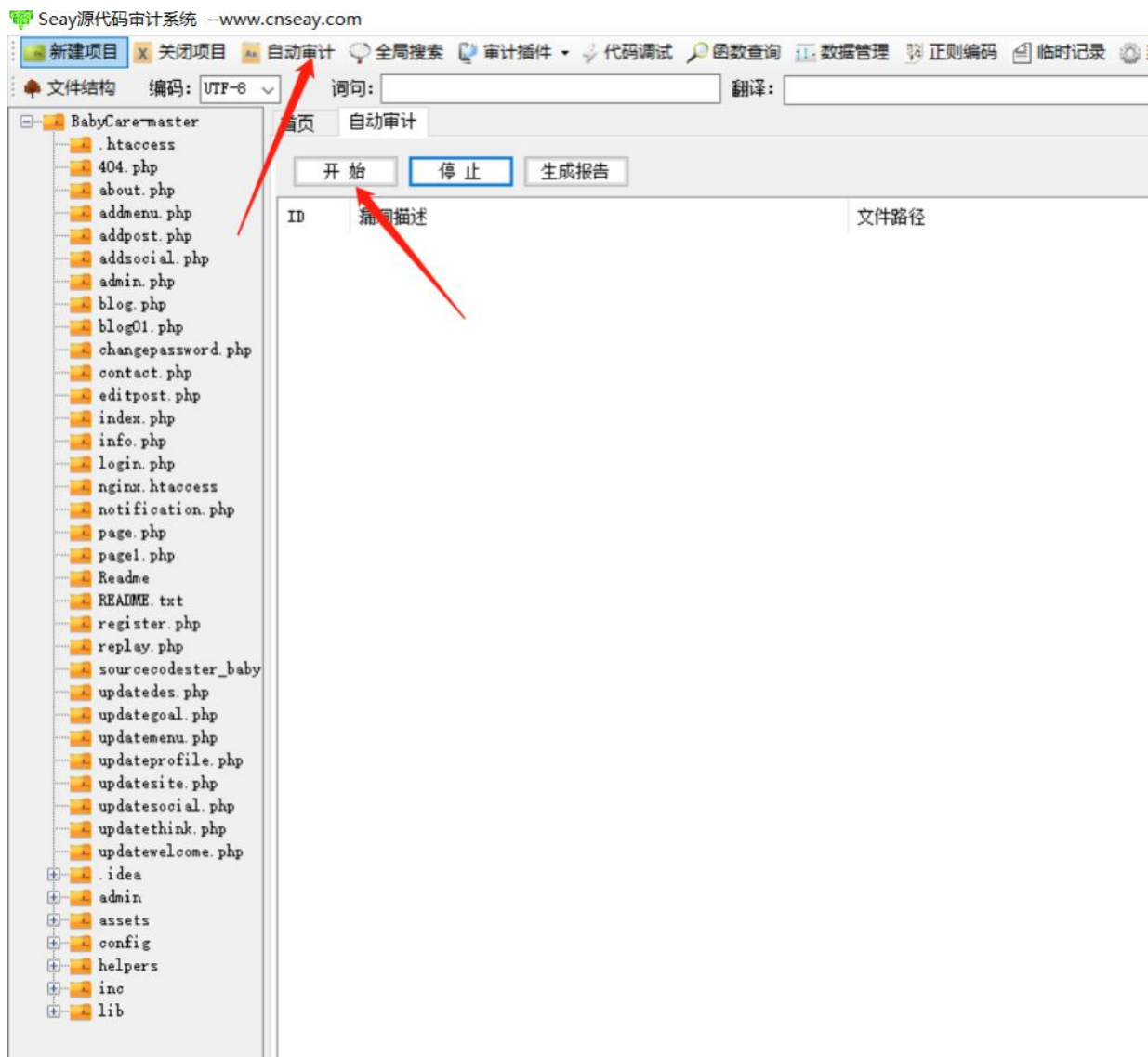
Seay 源代码审计系统简介

如果我们分析完了整个网站的功能点，那么是不是整个网站就不存在安全漏洞了呢？

肯定不是的，因为开发者的安全意识不同，所以整个程序的安全性也无法得到保证，说不定在某个角落中还存在危险代码，所以我么需要一个工具可以直接匹配程序中所有的危险代码，之后对危险的代码进行分析，已验证是否存在漏洞的可能性

使用 seay 源代码审计系统





点击漏洞描述对漏洞进行排序

ID	漏洞描述	文件路径	漏洞详情
10	phpinfo()函数, 可能存在SQL注入漏洞	/phpinfo()	//phpinfo();
13	SQL语句delete中条件变量无单引号保护, 可能存在SQL注入漏洞	unlink("assets/img/portfolio/".\$_POST['del_img']);	\$querydisplay = "UPDATE tb_inbox SET replay='".\$replay."' WHERE id='".\$msgid.'";
14	SQL语句delete中条件变量无单引号保护, 可能存在SQL注入漏洞	/updategoal.php	\$query = "UPDATE tb_about SET goalone='".\$goal."' WHERE id=1";
19	SQL语句delete中条件变量无单引号保护, 可能存在SQL注入漏洞	/admin/inbox.php	\$querydisplay = "UPDATE tb_inbox SET status='0' WHERE id='".\$msgid.'";
22	SQL语句delete中条件变量无单引号保护, 可能存在SQL注入漏洞	/admin/pagerole.php	\$querydisplay = "UPDATE tb_menu SET status='".\$value."' WHERE id='".\$roleid.'";
25	SQL语句delete中条件变量无单引号保护, 可能存在SQL注入漏洞	/admin/posts.php	\$querydisplay = "UPDATE tb_post SET status='".\$value."' WHERE id='".\$postid.'";
29	SQL语句delete中条件变量无单引号保护, 可能存在SQL注入漏洞	/admin/siteoptions.php	\$querydisplay = "UPDATE tb_social SET status='".\$value."' WHERE id='".\$socialid.'";
30	SQL语句delete中条件变量无单引号保护, 可能存在SQL注入漏洞	/admin/siteoptions.php	\$querydisplay = "UPDATE tb_about SET status='".\$value."' WHERE id='".\$roleid.'";
31	SQL语句delete中条件变量无单引号保护, 可能存在SQL注入漏洞	/admin/siteoptions.php	\$querydisplay = "UPDATE tb_site SET status='".\$value."' WHERE id='".\$roleid.'";
33	SQL语句delete中条件变量无单引号保护, 可能存在SQL注入漏洞	/admin/theme.php	\$queryset = "UPDATE tb_theme SET status='1' WHERE id='".\$setid.'";
34	SQL语句delete中条件变量无单引号保护, 可能存在SQL注入漏洞	/admin/users.php	\$querydisplay = "UPDATE tb_user SET type='".\$userrole."' WHERE id='".\$userid.'";
35	SQL语句delete中条件变量无单引号保护, 可能存在SQL注入漏洞	/admin/users.php	\$querydisplay = "UPDATE tb_user SET status='".\$value."' WHERE id='".\$userid.'";
1	SQL语句insert中插入变量无单引号保护, 可能存在SQL注入漏洞	/addmenu.php	\$query = "INSERT INTO tb_menu (name, image, body, tags, status) VALUES ('".\$name.', ' . \$unique_image . ', ' . \$body . ', ' . \$tags . ', ' . \$status . ')"
3	SQL语句insert中插入变量无单引号保护, 可能存在SQL注入漏洞	/addpost.php	\$query = "INSERT INTO tb_post (menuid, title, body, image, tags, status) VALUES ('".\$menuid.', ' . \$title . ', ' . \$body . ', ' . \$image . ', ' . \$tags . ', ' . \$status . ')"
4	SQL语句insert中插入变量无单引号保护, 可能存在SQL注入漏洞	/addpost.php	\$query = "INSERT INTO tb_post (menuid, title, body, image, tags, status) VALUES ('".\$menuid.', ' . \$title . ', ' . \$body . ', ' . \$image . ', ' . \$tags . ', ' . \$status . ')"
6	SQL语句insert中插入变量无单引号保护, 可能存在SQL注入漏洞	/addsocial.php	\$query = "INSERT INTO tb_social (name, link, status) VALUES ('".\$name.', ' . \$link . ', ' . \$status . ')"
7	SQL语句insert中插入变量无单引号保护, 可能存在SQL注入漏洞	/contact.php	\$query = "INSERT INTO tb_inbox (name, email, subject, message, status) VALUES ('".\$name.', ' . \$email . ', ' . \$subject . ', ' . \$message . ', ' . \$status . ')"
11	SQL语句select中条件变量无单引号保护, 可能存在SQL注入漏洞	/login.php	\$query = "SELECT * FROM tb_user WHERE email='".\$email.'" AND password='".\$password.'" AND stat
12	SQL语句select中条件变量无单引号保护, 可能存在SQL注入漏洞	/register.php	\$mailquery = "SELECT * FROM tb_user WHERE email='".\$email.'" limit 1";
20	SQL语句select中条件变量无单引号保护, 可能存在SQL注入漏洞	/admin/inbox.php	\$query = "SELECT * FROM tb_inbox WHERE id='".\$msgid.'";
23	SQL语句select中条件变量无单引号保护, 可能存在SQL注入漏洞	/admin/pagerole.php	\$query = "SELECT * FROM tb_menu WHERE id='".\$roleid.'";
26	SQL语句select中条件变量无单引号保护, 可能存在SQL注入漏洞	/admin/posts.php	\$query = "SELECT * FROM tb_post WHERE menuid='".\$find.'";
27	SQL语句select中条件变量无单引号保护, 可能存在SQL注入漏洞	/admin/posts.php	\$query = "SELECT * FROM tb_post WHERE id='".\$postid.'";
28	SQL语句select中条件变量无单引号保护, 可能存在SQL注入漏洞	/admin/profile.php	\$query = "SELECT * FROM tb_user WHERE id='".\$id.'";
32	SQL语句select中条件变量无单引号保护, 可能存在SQL注入漏洞	/admin/siteoptions.php	\$query = "SELECT * FROM tb_social WHERE id='".\$id.'";
36	SQL语句select中条件变量无单引号保护, 可能存在SQL注入漏洞	/inc/contentsectionpage.php	\$querypost = "SELECT * FROM tb_post WHERE menuid='".\$id.'" AND status=1 LIMIT 1";
37	SQL语句select中条件变量无单引号保护, 可能存在SQL注入漏洞	/inc/contentsectionpage.php	\$querypost = "SELECT * FROM tb_post WHERE menuid='".\$id.'" AND id='".\$postid.'" AND status=1";
38	SQL语句select中条件变量无单引号保护, 可能存在SQL注入漏洞	/inc/contentsectionpage.php	\$querysubmenu = "SELECT * FROM tb_post WHERE menuid='".\$id.'" AND status=1";
39	SQL语句select中条件变量无单引号保护, 可能存在SQL注入漏洞	/inc/contentsectionpage.php	\$querypost = "SELECT * FROM tb_post WHERE menuid='".\$id.'" AND status=1";
40	SQL语句select中条件变量无单引号保护, 可能存在SQL注入漏洞	/inc/contentsectionpage.php	\$count = "SELECT * FROM tb_post WHERE menuid='".\$id.'" AND status=1"; //check query for post
41	SQL语句select中条件变量无单引号保护, 可能存在SQL注入漏洞	/inc/contentsectionpage.php	\$query = "SELECT * FROM tb_menu WHERE id='".\$id.'" AND status=1";
2	存在文件上传, 注意上传类型是否可控	/addmenu.php	move_uploaded_file(\$file_temp, \$uploaded_image);
5	存在文件上传, 注意上传类型是否可控	/addpost.php	move_uploaded_file(\$file_temp, \$uploaded_image);
9	存在文件上传, 注意上传类型是否可控	/editpost.php	move_uploaded_file(\$file_temp, \$uploaded_image);
16	存在文件上传, 注意上传类型是否可控	/updatemenu.php	move_uploaded_file(\$file_temp, \$uploaded_image);
18	存在文件上传, 注意上传类型是否可控	/updatevalcom.php	move_uploaded_file(\$file_temp, \$uploaded_image);
8	文件操作函数中存在变量, 可能存在任意文件读取/删除/修改漏洞	/editpost.php	unlink("assets/img/portfolio/".\$_POST['del_img']);
15	文件操作函数中存在变量, 可能存在任意文件读取/删除/修改漏洞	/updatemenu.php	unlink("assets/img/portfolio/".\$_POST['del_img']);
17	文件操作函数中存在变量, 可能存在任意文件读取/删除/修改漏洞	/updatevalcom.php	unlink("assets/img/".\$_POST['del_img']);
21	文件操作函数中存在变量, 可能存在任意文件读取/删除/修改漏洞	/admin/pagerole.php	unlink("assets/img/portfolio/".\$_POST['del_img']);

进度: 状态: 扫描完成, 发现41个可疑漏洞, 花费时间4.21秒

工具原理分析

我们这里看看为什么这个工具能够找到这些漏洞的原因是什么

通过系统配置-查看规则管理

源代码审计系统 --www.cnseay.com

新建项目 关闭项目 自动审计 全局搜索 审计插件 代码调试 函数查询 数据管理 正则编码 临时记录 系统配置 关于系统

文件结构 编码: UTF-8 词句: 翻译: 规则管理 系统配置

开始 停止 生成报告

ID	漏洞描述	文件路径	漏洞详情
10	phpinfo()函数, 可能存在敏感信息泄露漏洞	/info.php	//phpinfo();
13	SQL语句delete中条件变量无单引号保护, 可能存在SQL注入漏洞	/replay.php	\$querydisplay = "UPDATE tl
14	SQL语句delete中条件变量无单引号保护, 可能存在SQL注入漏洞	/updategoal.php	\$query = "UPDATE tb_about
19	SQL语句delete中条件变量无单引号保护, 可能存在SQL注入漏洞	/admin/inbox.php	\$querydisplay = "UPDATE tl
22	SQL语句delete中条件变量无单引号保护, 可能存在SQL注入漏洞	/admin/pagerole.php	\$querydisplay = "UPDATE tl

源代码审计系统 --www.cnseay.com

关闭项目 自动审计 全局搜索 审计插件 代码调试 函数查询 数据管理 正则编码 临时记录 系统配置 关于系统

编码: UTF-8 词句: 翻译: 规则管理

规则信息

ID	详细规则	规则描述
1	\b(include require _once){0,1}\{s{1,5}\}\s{0,...	文件包含函数中存在变量, 可能存在文件包含漏洞
2	\bpreg_replace\{s{0,5}\}.*\{s{0,2}\}e\{s{0,2}\}...	preg_replace的/e模式, 且存在可控变量, 可能存在代码执行漏洞
3	\bphpinfo\{s{0,5}\}\{s{0,5}\}	phpinfo()函数, 可能存在敏感信息泄露漏洞
4	\bcall_user_func(_array){0,1}\{s{0,5}\}\\$w{1,...	call_user_func函数参数包含变量, 可能存在代码执行漏洞
5	\b(file_get_contents fopen readfile fgets fread ...	读取文件函数中存在变量, 可能存在任意文件读取漏洞
6	\b(system passthru popen exec shell_exec escap...	命令执行函数中存在变量, 可能存在任意命令执行漏洞
7	\b(mb_){0,1}parse_str\{s{0,10}\}\{s{0,40}\}\\$w{1,...	parse_str函数中存在变量, 可能存在变量覆盖漏洞
8	\\$ {0,1}\\$w{1,20}\{s{0,1}\}\{s{0,1}\}\{s{0,1}\}\{s{0,1}\}...	双斜杠符号可能存在于变量覆盖漏洞
9	[*](HTTP_CLIENT_IP HTTP_X_FORWARDED_FOR HTTP...	获取IP地址方式可伪造, HTTP_REFERER可伪造, 常见引发SQL注入等漏洞
10	\b(unlink copy fwrite file_put_contents fread ...	文件操作函数中存在变量, 可能存在任意文件读取/删除/修改/写入等漏洞
11	\b(extract)\{s{0,5}\}\{s{0,30}\}\\$w{1,20}\{s{0,1}\}\{s{0,1}\}...	extract函数中存在变量, 可能存在变量覆盖漏洞
12	\\$w{1,20}\{s{0,1}\}\{s{0,1}\}\{s{0,1}\}\{s{0,1}\}\{s{0,1}\}...	可能存在代码执行漏洞, 或者此处是后门
13	'(?!.*)baddslashes'\{s{0,40}\}\b{0,1}urldec...	urlencode绕过GPC, stripslashes会取消GPC转义字符
14	'\{s{0,1}\}\{s{0,1}\}\{s{0,1}\}\{s{0,1}\}\{s{0,1}\}\{s{0,1}\}...	反引号中包含变量, 变量可控会导致命令执行漏洞
15	\barray_map\{s{0,4}\}\{s{0,4}\}\{s{0,20}\}\\$w{1,20}\{...	array_map参数包含变量, 变量可控可能会导致代码执行漏洞
16	select\s{1,4}\{s{1,60}\}from.\{s{1,50}\}\bwhere\s{1,3}...	SQL语句select中条件变量无单引号保护, 可能存在SQL注入漏洞
17	delete\s{1,4}\{s{1,60}\}from.\{s{1,50}\}\bwhere\s{1,3}...	SQL语句delete中条件变量无单引号保护, 可能存在SQL注入漏洞
18	insert\s{1,5}\{s{1,5}\}\{s{1,60}\}\\$w{1,20}\{s{0,1}\}\{s{0,1}\}...	SQL语句insert中插入变量无单引号保护, 可能存在SQL注入漏洞
19	update\s{1,4}\{s{1,30}\}\{s{1,3}\}set\s{1,5}\{s{1,60}\}\{...	SQL语句update中条件变量无单引号保护, 可能存在SQL注入漏洞
20	\b(eval assert)\{s{0,10}\}\{s{0,60}\}\\$w{1,20}\{s{0,1}\}\{s{0,1}\}...	eval或者assert函数中存在变量, 可能存在代码执行漏洞
21	\b(echo print print_r)\{s{0,5}\}\{s{0,1}\}\{s{0,60}\}\{...	echo等输出中存在可控变量, 可能存在XSS漏洞
22	\b(header)\{s{0,5}\}\{s{0,30}\}\{s{0,1}\}\{s{0,1}\}\{s{0,1}\}...	header函数或者js location有可控参数, 存在任意跳转或http头污染漏洞
23	\b(move_uploaded_file)\{s{0,5}\}\{s{0,1}\}\{s{0,1}\}\{s{0,1}\}...	存在文件上传, 注意上传类型是否可控
24	select\s{1,4}\{s{1,60}\}from.\{s{1,50}\}\bwhere\s{1,3}...	SQL语句select中条件变量无单引号注入, 可能存在SQL注入漏洞

我们发现所有的漏洞都是通过正则表达式匹配找到的, 即是通过正则表达式匹配代码中的每一行代码, 当符合正则表达式的规则时, 输出漏洞描述

基本上的代码审计工具原理都是类似